
This content is from the eCFR and is authoritative but unofficial.

Title 33 —Navigation and Navigable Waters

Chapter I —Coast Guard, Department of Homeland Security

Subchapter H —Maritime Security

Part 101 —Maritime Security: General

Authority: 46 U.S.C. 70101-70104 and 70124; Executive Order 12656, 3 CFR, 1988 Comp., p. 585; 33 CFR 1.05-1, 6.04-11, 6.14, 6.16, and 6.19; Department of Homeland Security Delegation No. 00170.1, Revision No. 01.4.

Source: USCG-2003-14792, 68 FR 39278, July 1, 2003, unless otherwise noted.

Subpart F Cybersecurity

- § 101.600 Purpose.
- § 101.605 Applicability.
- § 101.610 Federalism.
- § 101.615 Definitions.
- § 101.620 Owner or operator.
- § 101.625 Cybersecurity Officer.
- § 101.630 Cybersecurity Plan.
- § 101.635 Drills and exercises.
- § 101.640 Records and documentation.
- § 101.645 Communications.
- § 101.650 Cybersecurity measures.
- § 101.655 Cybersecurity compliance dates.
- § 101.660 Cybersecurity compliance documentation.
- § 101.665 Noncompliance, waivers, and equivalents.
- § 101.670 Severability.

Editorial Note: Nomenclature changes to part 101 appear by USCG-2008-0179, 73 FR 35009, June 19, 2008.

Subpart F—Cybersecurity

Source: 90 FR 6447, Jan. 17, 2025, unless otherwise noted.

§ 101.600 Purpose.

The purpose of this subpart is to set minimum cybersecurity requirements for U.S.-flagged vessels, facilities, and Outer Continental Shelf (OCS) facilities to safeguard and ensure the security and resilience of the Marine Transportation System (MTS).

§ 101.605 Applicability.

- (a) This subpart applies to the owners and operators of U.S.-flagged vessels, facilities, and OCS facilities required to have a security plan under 33 CFR parts 104, 105, and 106.
- (b) This subpart does not apply to any foreign-flagged vessels subject to 33 CFR part 104.

§ 101.610 Federalism.

Consistent with § 101.112(b), with respect to a facility regulated under 33 CFR part 105 to which this subpart applies, the regulations in this subpart have preemptive effect over a State or local law or regulation insofar as the State or local law or regulation applicable to the facility conflicts with these regulations, either by actually conflicting or by frustrating an overriding Federal need for uniformity.

§ 101.615 Definitions.

Unless otherwise specified, as used in this subpart:

Approved list means an owner or operator's authoritative catalog for products that meet cybersecurity requirements.

Backup means a copy of physical or virtual files or databases stored separately for preservation and recovery. It may also refer to the process of creating a copy.

Credentials means a set of data attributes that uniquely identifies a system entity such as a person, an organization, a service, or a device, and attests to one's right to access to a particular system.

Critical Information Technology (IT) or Operational Technology (OT) systems means any Information Technology (IT) or Operational Technology (OT) system used by the vessel, facility, or OCS facility that, if compromised or exploited, could result in a transportation security incident (TSI), as determined by the Cybersecurity Officer (CySO) in the Cybersecurity Plan. Critical IT or OT systems include those business support services that, if compromised or exploited, could result in a TSI. This term includes systems whose ownership, operation, maintenance, or control is delegated wholly or in part to any other party.

Cyber incident means an occurrence that actually jeopardizes, without lawful authority, the integrity, confidentiality, or availability of information or an information system, or actually jeopardizes, without lawful authority, an information system.

Cyber Incident Response Plan means a set of predetermined and documented procedures to respond to a cyber incident. It is a document that gives the owner or operator or a designated CySO instructions on how to respond to a cyber incident and pre-identifies key roles, responsibilities, and decision-makers.

Cyber threat means an action, not protected by the First Amendment to the Constitution of the United States, on or through an information system that may result in an unauthorized effort to adversely impact the security, availability, confidentiality, or integrity of an information system or information that is stored on, processed by, or transiting an information system. The term "cyber threat" does not include any action that solely involves a violation of a consumer term of service or a consumer licensing agreement.

Cybersecurity Assessment means the appraisal of the risks facing an entity, asset, system, or network, organizational operations, individuals, geographic area, other organizations, or society, and includes identification of relevant vulnerabilities and threats and determining the extent to which adverse circumstances or events could result in operational disruption and other harmful consequences.

Cybersecurity Officer, or CySO, means the person designated as responsible for the development, implementation, and maintenance of the cybersecurity portions of the Vessel Security Plan (VSP), Facility Security Plan (FSP), or Outer Continental Shelf (OCS) FSP, and for liaison with the Captain of the Port (COTP) and Company, Vessel, and Facility Security Officers. The owner or operator may designate an alternate CySO(s) to assist with the duties and responsibilities of the CySO, including during periods when the CySO is on leave, unavailable, or unable to perform their duties. Hereafter, “CySO” will refer to both the CySO and the alternate CySO(s), as applicable.

Cybersecurity Plan means a plan developed as a part of the VSP, FSP, or OCS FSP to ensure application and implementation of cybersecurity measures designed to protect the owners' or operators' systems and equipment, as required by this part. A Cybersecurity Plan is either included in a VSP, FSP, or OCS FSP; as an annex to a VSP, FSP, or OCS FSP; provided in a separate submission from the VSP, FSP, or OCS FSP; or addressed through an Alternative Security Program.

Cybersecurity risk means threats to and vulnerabilities of information or information systems and any related consequences caused by or resulting from unauthorized access, use, disclosure, degradation, disruption, modification, or destruction of such information or information systems, including such related consequences caused by an act of terrorism. It does not include any action that solely involves a violation of a consumer term of service or a consumer licensing agreement.

Cybersecurity vulnerability means any attribute of hardware, software, process, or procedure that could enable or facilitate the defeat of a security control.

Encryption means any procedure used in cryptography to convert plain text into cipher text to prevent anyone but the intended recipient from reading that data.

Executable code means any object code, machine code, or other code readable by a computer when loaded into its memory and used directly by such computer to execute instructions.

Exploitable channel means any information channel (such as a portable media device and other hardware) that allows for the violation of the security policy governing the information system and is usable or detectable by subjects external to the trusted user.

Firmware means computer programs (which are stored in and executed by computer hardware) and associated data (which is also stored in the hardware) that may be dynamically written or modified during execution.

Hardware means, collectively, the equipment that makes up physical parts of a computer, including its electronic circuitry, together with keyboards, readers, scanners, and printers.

Human-Machine Interface, or HMI, means the hardware or software through which an operator interacts with a controller for industrial systems. An HMI can range from a physical control panel with buttons and indicator lights to an industrial personal computer with a color graphics display running dedicated HMI software.

Information system means an interconnected set of information resources under the same direct management control that shares common functionality. A system normally includes hardware, software data, applications, communications, and people. It includes the application of IT, OT, or a combination of both.

Information Technology, or IT, means any equipment or interconnected system or subsystem of equipment, used in the acquisition, storage, analysis, evaluation, manipulation, management, movement, control, display, switching, interchange, transmission, or reception of data or information.

Known Exploited Vulnerability, or KEV, means a computer vulnerability that has been exploited in the past.

Log means a record of the events occurring within an organization's systems and networks.

Multifactor authentication means a layered approach to securing data and applications for a system that requires users to present more than one distinct authentication factor for successful authentication. Multifactor authentication can be performed using a multifactor authenticator or by a combination of authenticators that provide different factors. The three authentication factors are something you know, something you have, and something you are.

Network means information system(s) implemented with a collection of interconnected components. A network is a collection of computers, servers, mainframes, network devices, peripherals, or other devices connected to allow data sharing. A network consists of two or more computers that are linked in order to share resources, exchange files, or allow electronic communications.

Network map means a visual representation of internal network topologies and components.

Network segmentation means a physical or virtual architectural approach that divides a network into multiple segments, each acting as its own subnetwork, to provide additional security and control that can help prevent or minimize the impact of a cyber incident.

Operational Technology, or OT, means programmable systems or devices that interact with the physical environment (or manage devices that interact with the physical environment). These systems or devices detect or cause a change through the monitoring or control of devices, processes, and events.

Patching means updating software and operating systems to address cybersecurity vulnerabilities within a program or product.

Penetration test means a test of the security of a computer system or software application by attempting to compromise its security and the security of an underlying operating system and network component configurations.

Principle of least privilege means that an individual should be given only those privileges that are needed to complete a task. Further, the individual's function, not identity, should control the assignment of privileges.

Privileged user means a user who is authorized (and, therefore, trusted) to perform security functions that ordinary users are not authorized to perform.

Reportable cyber incident means an incident that leads to or, if still under investigation, could reasonably lead to any of the following: Substantial loss of confidentiality, integrity, or availability of a covered information system, network, or OT system; Disruption or significant adverse impact on the reporting entity's ability to engage in business operations or deliver goods or services, including those that have a potential for significant impact on public health or safety or may cause serious injury or death; Disclosure or unauthorized access directly or indirectly of nonpublic personal information of a significant number of individuals; Other potential operational disruption to critical infrastructure systems or assets; or Incidents that otherwise may lead to a transportation security incident as defined in 33 CFR 101.105.

Risk means a measure of the extent to which an entity is threatened by a potential circumstance or event, and typically is a function of: The adverse impact, or magnitude of harm, that would arise if the circumstance or event occurs; and the likelihood of occurrence.

Software means a set of instructions, data, or programs used to operate a computer and execute specific tasks.

Supply chain means a system of organizations, people, activities, information, and resources for creating computer products and offering IT services to their customers.

Threat means any circumstance or event with the potential to adversely impact organizational operations (including mission, functions, image, or reputation), organizational assets, individuals, other organizations, or the Nation through an information system through unauthorized access, destruction, disclosure, modification of information, or denial of service.

Vulnerability means a characteristic or specific weakness that renders an organization or asset (such as information or an information system) open to exploitation by a given threat or susceptible to a given hazard.

Vulnerability scan means a technique used to identify hosts or host attributes and associated vulnerabilities.

§ 101.620 Owner or operator.

- (a) Each owner or operator of a U.S.-flagged vessel, facility, or OCS facility is responsible for compliance with the requirements of this subpart.
- (b) For each U.S.-flagged vessel, facility, or OCS facility, the owner or operator must—
 - (1) Ensure a Cybersecurity Plan is developed, approved, and maintained;
 - (2) Define in Section 1 of the Cybersecurity Plan the cybersecurity organizational structure and identify each person exercising cybersecurity duties and responsibilities within that structure, with the support needed to fulfill those obligations;
 - (3) Designate, in writing, by name and by title, a Cybersecurity Officer (CySO) who is accessible to the Coast Guard 24 hours a day, 7 days a week, and identify how the CySO can be contacted at any time;
 - (4) Ensure that cybersecurity exercises, audits, and inspections, as well as the Cybersecurity Assessment, are conducted as required by this part and in accordance with the Cybersecurity Plan (see § 101.625(d)(1), (3), (6) and (7));
 - (5) Ensure that the U.S.-flagged vessel, facility, or OCS facility operates in compliance with the approved Cybersecurity Plan;
 - (6) Ensure the development, approval, and execution of the Cyber Incident Response Plan; and
 - (7) For entities that have not reported to the Coast Guard pursuant to, or are not subject to, 33 CFR 6.16-1, ensure all reportable cyber incidents are reported to the National Response Center (NRC).

§ 101.625 Cybersecurity Officer.

- (a) **Other duties.** The Cybersecurity Officer (CySO) may serve in other roles or positions and may perform other duties within the owner's or operator's organization (U.S.-flagged vessel, facility, or OCS facility), provided the person is able to perform the duties and responsibilities required of the CySO by this part.
- (b) **Serving as CySO for Multiple Vessels, Facilities, or OCS Facilities.** The same person may serve as the CySO for more than one U.S.-flagged vessel, facility, or OCS facility. If a person serves as the CySO for more than one U.S.-flagged vessel, facility, or OCS facility, the name of each U.S.-flagged vessel, facility, or OCS facility for which that person is the CySO must be listed in the Cybersecurity Plan of each U.S.-flagged vessel, facility, or OCS facility for which that person is the CySO.
- (c) **Assigning Duties Permitted.** The CySO may assign security duties to other U.S.-flagged vessel, facility, or OCS facility personnel; however, the CySO retains ultimate responsibility for these duties.

- (d) **Responsibilities.** For each U.S.-flagged vessel, facility, or OCS facility for which they are designated, the CySO must—
- (1) Ensure that the Cybersecurity Assessment is conducted as required by this part;
 - (2) Ensure the cybersecurity measures in the Cybersecurity Plan are developed, implemented, and operating as intended;
 - (3) Ensure that an annual audit of the Cybersecurity Plan and its implementation is conducted and, if necessary, ensure that the Cybersecurity Plan is updated;
 - (4) Ensure the Cyber Incident Response Plan is executed and exercised;
 - (5) Ensure the Cybersecurity Plan is exercised in accordance with § 101.635(c);
 - (6) Arrange for cybersecurity inspections, which may be conducted as their own inspections, or in conjunction with any scheduled Coast Guard inspection of a U.S.-flagged vessel, facility, or OCS facility;
 - (7) Ensure the prompt correction of problems identified by exercises, audits, or inspections;
 - (8) Enhance the cybersecurity awareness and vigilance of personnel;
 - (9) Ensure adequate cybersecurity training of personnel;
 - (10) Ensure all reportable cyber incidents are recorded and reported to the owner or operator;
 - (11) Ensure that records required by this part are maintained in accordance with § 101.640;
 - (12) Ensure any reports as required by this part have been prepared and submitted;
 - (13) Ensure that the Cybersecurity Plan, as well as proposed amendments to cybersecurity measures included in the Plan, are submitted for approval to the cognizant COTP or the Officer in Charge, Marine Inspections (OCMI) for facilities or OCS facilities, or to the Marine Safety Center (MSC) for U.S.-flagged vessels, prior to amending the Cybersecurity Plan, in accordance with § 101.630;
 - (14) Ensure relevant security and management personnel are briefed regarding changes in cybersecurity conditions on board the U.S.-flagged vessel, facility, or OCS facility; and
 - (15) Ensure identification and mitigation of all KEVs in critical IT or OT systems, without delay.
- (e) **Qualifications.** The CySO must have general knowledge, through training, education, or equivalent job experience, in the following:
- (1) General vessel, facility, or OCS facility operations and conditions;
 - (2) General cybersecurity guidance and best practices;
 - (3) The vessel, facility, or OCS facility's Cyber Incident Response Plan;
 - (4) The vessel, facility, or OCS facility's Cybersecurity Plan;
 - (5) Cybersecurity equipment and systems;
 - (6) Methods of conducting cybersecurity audits, inspections, control, and monitoring techniques;
 - (7) Relevant laws and regulations pertaining to cybersecurity;
 - (8) Instruction techniques for cybersecurity training and education;

- (9) Handling of Sensitive Security Information and security related communications;
- (10) Current cybersecurity threat patterns and KEVs;
- (11) Recognizing characteristics and behavioral patterns of persons who are likely to threaten security; and
- (12) Conducting and assessing cybersecurity drills and exercises.

§ 101.630 Cybersecurity Plan.

- (a) **General.** The CySO must develop, implement, and verify a Cybersecurity Plan for U.S.-flagged vessels, facilities, or OCS facilities. The Cybersecurity Plan must reflect all cybersecurity measures required in this subpart, as appropriate, to mitigate risks identified during the Cybersecurity Assessment. The Plan must describe in detail how the requirements of subpart F will be met. The Cybersecurity Plan may be included in a VSP, FSP, or an OCS FSP; as an annex to the VSP, FSP, or OCS FSP; as part of an approved Alternative Security Program; or may be provided in a separate submission from the VSP, FSP, or OCS FSP.
- (b) **Protecting sensitive security information.** The Cybersecurity Plan is sensitive security information and must be protected in accordance with 49 CFR part 1520.
- (c) **Format.** The owner or operator must ensure that the Cybersecurity Plan consists of the individual sections listed in this paragraph. If the Cybersecurity Plan does not follow the order as it appears on the list, the owner or operator must ensure that the Plan contains an index identifying the location of each of the following sections:
 - (1) Cybersecurity organization and identity of the CySO;
 - (2) Personnel training;
 - (3) Drills and exercises;
 - (4) Records and documentation;
 - (5) Communications;
 - (6) Cybersecurity systems and equipment, with associated maintenance;
 - (7) Cybersecurity measures for access control, including the computer, IT, and OT access areas;
 - (8) Physical security controls for IT and OT systems;
 - (9) Cybersecurity measures for monitoring;
 - (10) Audits and amendments to the Cybersecurity Plan;
 - (11) Reports of all cybersecurity audits and inspections, to include documentation of resolution or mitigation of all identified vulnerabilities;
 - (12) Documentation of all identified, unresolved vulnerabilities, to include those that are intentionally unresolved due to owner or operator risk acceptance;
 - (13) Cyber incident reporting procedures in accordance with part 101 of this subchapter; and
 - (14) Cybersecurity Assessment.

- (d) **Submission and approval.** Each owner or operator must submit one copy of their Cybersecurity Plan for review and approval to the cognizant COTP or the OCMI for a facility or OCS facility, or to the MSC for a U.S.-flagged vessel.
- (1) The COTP, OCMI, or MSC will evaluate each submission for compliance with this part, and either—
 - (i) Approve the Cybersecurity Plan and return a letter to the owner or operator indicating approval and any conditional approval;
 - (ii) Require additional information or revisions to the Cybersecurity Plan and return a copy to the owner or operator with a brief description of the required revisions or additional information; or
 - (iii) Disapprove the Cybersecurity Plan and return a copy to the owner or operator with a brief statement of the reasons for disapproval.
 - (iv) If the cognizant COTP, OCMI, or MSC requires additional time to review the Plan, they may return a written acknowledgement to the owner or operator stating that the Coast Guard will review the Cybersecurity Plan submitted for approval, and that the U.S.-flagged vessel, facility, or OCS facility may continue to operate as long as it remains in compliance with the submitted Cybersecurity Plan.
 - (2) Owners or operators submitting one Cybersecurity Plan to cover two or more U.S.-flagged vessels, facilities, or OCS facilities of similar operations must ensure the Plan addresses the specific cybersecurity risks for each U.S.-flagged vessel, facility, or OCS facility.
 - (3) A Plan that is approved by the COTP, OCMI, or MSC is valid for 5 years from the date of its approval.
- (e) **Amendments to the Cybersecurity Plan.**
- (1) Amendments to a Coast Guard-approved Cybersecurity Plan must be initiated by either—
 - (i) The owner or operator or the CySO; or
 - (ii) When the COTP, OCMI, or MSC finds that the Cybersecurity Plan no longer meets the requirements in this part, the Plan will be returned to the owner or operator with a letter explaining why the Plan no longer meets the requirements and requires amendment. The owner or operator will have at least 60 days to submit its proposed amendments. Until the amendments are approved, the owner or operator must ensure temporary cybersecurity measures are implemented to the satisfaction of the Coast Guard.
 - (2) Proposed amendments to the Cybersecurity Plan must be sent to the Coast Guard at least 30 days before the proposed amendment's effective date. The Coast Guard will approve or disapprove the proposed amendment in accordance with this part.
 - (i) Nothing in this section should be construed as limiting the owner or operator of the U.S.-flagged vessel, facility, or OCS facility from the timely implementation of such additional security measures not enumerated in the approved VSP, FSP, or OCS FSP as necessary to address exigent security situations.
 - (ii) In such cases, the owner or operator must notify the cognizant COTP for a facility or OCS facility, or the MSC for U.S.-flagged vessels, by the most rapid means practicable as to the nature of the additional measures, the circumstances that prompted these additional measures, and the period of time these additional measures are expected to be in place.

- (3) If the owner or operator has changed, the CySO must amend the Cybersecurity Plan as soon as reasonably practicable in light of the individual circumstances, but, in any case, not longer than 96 hours, to include the name and contact information of the new owner or operator and submit the affected portion of the Plan for review and approval in accordance with this part.
- (4) If the CySO has changed, the Coast Guard must be notified as soon as reasonably practicable in light of the individual circumstances, but, in any case, not longer than 96 hours, and the affected portion of the Cybersecurity Plan must be amended and submitted to the Coast Guard for review and approval in accordance with this part as soon as reasonably practicable in light of the individual circumstances, but, in any case, not longer than 96 hours.

(f) **Audits.**

- (1) The CySO must ensure that an audit of the Cybersecurity Plan and its implementation is performed annually, beginning no later than 1 year from the initial date of approval. The CySO must attach a report to the Plan certifying that the Plan meets the applicable requirements of this subpart.
- (2) In addition to the annual audit, the CySO must ensure that an audit of the Cybersecurity Plan occurs if there is a change in the owner or operator of the U.S.-flagged vessel, facility, or OCS facility, or if there have been modifications to the cybersecurity measures, including, but not limited to, physical access, incident response procedures, security measures, or operations.
- (3) Additional audits of the Cybersecurity Plan as a result of modifications to the U.S.-flagged vessel, facility, or OCS facility, or because of changes to the cybersecurity measures in accordance with paragraph (f)(2) of this section, may be limited to those sections of the Plan affected by the modifications.
- (4) Personnel conducting internal audits of the cybersecurity measures specified in the Plan or evaluating its implementation must—
 - (i) Have knowledge of methods of conducting audits and inspections, as well as access control and monitoring techniques;
 - (ii) Not have regularly assigned cybersecurity duties for the U.S.-flagged vessel, facility, or OCS facility being audited; and
 - (iii) Be independent of any cybersecurity measures being audited.
- (5) If the results of an audit require amending the Cybersecurity Plan, the CySO must submit, in accordance with this part, the amendments to the Coast Guard for review and approval no later than 30 days after completion of the audit.

§ 101.635 Drills and exercises.

(a) **General.**

- (1) Drills and exercises must be used to test the proficiency of the U.S.-flagged vessel, facility, and OCS facility personnel in assigned cybersecurity duties and the effective implementation of the VSP, FSP, OCS FSP, and Cybersecurity Plan. The drills and exercises must enable the CySO to identify any related cybersecurity deficiencies that need to be addressed.

- (2) The drill or exercise requirements specified in this section may be satisfied with the implementation of cybersecurity measures required by the VSP, FSP, OCS FSP, and Cybersecurity Plan as the result of a cyber incident, as long as the U.S.-flagged vessel, facility, or OCS facility achieves and documents attainment of drill and exercise goals for the cognizant COTP.

(b) **Drills.**

- (1) The CySO must ensure that cybersecurity drills are conducted at least twice each calendar year. Cybersecurity drills may be held in conjunction with other security or non-security drills, as required by 33 CFR 104.230, 105.220, or 106.225, where appropriate.
- (2) Drills must test individual elements of the Cybersecurity Plan, including responses to cybersecurity threats and incidents. Cybersecurity drills must take into account the types of operations of the U.S.-flagged vessel, facility, or OCS facility; changes to the U.S.-flagged vessel, facility, or OCS facility personnel; the type of vessel a facility is serving; and other relevant circumstances.
- (3) If a vessel is moored at a facility on a date a facility has planned to conduct any drills, the facility cannot require the vessel or vessel personnel to be a part of or participate in the facility's scheduled drill.

(c) **Exercises.**

- (1) Exercises must be conducted at least once each calendar year, with no more than 18 months between exercises.
- (2) Exercises may be—
 - (i) Full-scale or live;
 - (ii) Tabletop simulation;
 - (iii) Combined with other appropriate exercises as required by 33 CFR 104.230, 105.220, or 106.225; or
 - (iv) A combination of the elements in paragraphs (c)(2)(i) through (iii) of this section.
- (3) Exercises may be vessel-, facility-, or OCS facility-specific, or part of a cooperative exercise program to exercise applicable vessel, facility, and OCS facility Cybersecurity Plans or comprehensive port exercises.
- (4) Each exercise must test communication and notification procedures and elements of coordination, resource availability, and response.
- (5) Exercises are a full test of the cybersecurity program and must include the substantial and active participation of the CySO(s).
- (6) If any corrective action identified during an exercise is needed, it must be addressed and documented as soon as possible.

§ 101.640 Records and documentation.

All records, reports, and other documents mentioned in this subpart must be created and maintained in accordance with 33 CFR 104.235 for U.S.-flagged vessels, 105.225 for facilities, and 106.230 for OCS facilities. At a minimum, the records must be created for the following activities: training, drills, exercises, cybersecurity threats, reportable cyber incidents, and audits of the Cybersecurity Plan.

§ 101.645 Communications.

- (a) The CySO must have a means to effectively notify owners or operators and personnel of a U.S.-flagged vessel, facility, or OCS facility of changes in cybersecurity conditions at the U.S.-flagged vessel, facility, and OCS facility and document these means in Section 5 of the Cybersecurity Plan.
- (b) Communication systems and procedures must allow effective and continuous communications between U.S.-flagged vessel, facility, and OCS facility security personnel, vessels interfacing with a facility or an OCS facility, the cognizant COTP, and national and local authorities with security responsibilities.

§ 101.650 Cybersecurity measures.

- (a) **Account security measures.** Each owner or operator of a U.S.-flagged vessel, facility, or OCS facility must ensure, at a minimum, the following account security measures are in place and documented in Section 7 of the Cybersecurity Plan:
 - (1) Automatic account lockout after repeated failed login attempts must be enabled on all password-protected IT systems;
 - (2) Default passwords must be changed before using any IT or OT systems. When changing default passwords is not feasible, appropriate compensating security controls must be implemented and documented;
 - (3) A minimum password strength must be maintained on all IT and OT systems that are technically capable of password protection;
 - (4) Multifactor authentication must be implemented on password-protected IT and remotely accessible OT systems. When multifactor authentication is not feasible, appropriate compensating security controls must be implemented and documented;
 - (5) The principle of least privilege must be applied to administrator or otherwise privileged accounts on both IT and OT systems;
 - (6) The owner or operator must ensure that users maintain separate credentials on critical IT and OT systems; and
 - (7) The owner or operator must ensure that user credentials are removed or revoked when a user leaves the organization.
- (b) **Device security measures.** Each owner or operator or designated CySO of a U.S.-flagged vessel, facility, or OCS facility must ensure the following device security measures are in place, addressed in Section 6 of the Cybersecurity Plan, and made available to the Coast Guard upon request:
 - (1) Develop and maintain a list of approved hardware, firmware, and software that may be installed on IT or OT systems. Any hardware, firmware, and software installed on IT and OT systems must be on the owner- or operator-approved list;
 - (2) Ensure applications running executable code are disabled by default on critical IT and OT systems;
 - (3) Maintain an accurate inventory of network-connected systems, including designation of critical IT and OT systems; and
 - (4) Develop and maintain accurate documentation identifying the network map and OT device configuration information.

- (c) **Data security measures.** Each owner or operator or designated CySO of a U.S.-flagged vessel, facility, or OCS facility must ensure the following data security measures are in place and documented in Section 4 of the Cybersecurity Plan:
- (1) Logs must be securely captured, stored, and protected so that they are accessible only by privileged users; and
 - (2) Effective encryption must be deployed to maintain confidentiality of sensitive data and integrity of IT and OT traffic, when technically feasible.
- (d) **Cybersecurity training for personnel.** The training program to address requirements under this paragraph must be documented in Sections 2 and 4 of the Cybersecurity Plan.
- (1) All personnel with access to the IT or OT systems, including contractors, whether part-time, full-time, temporary, or permanent, must have cybersecurity training in the following topics:
 - (i) Relevant provisions of the Cybersecurity Plan;
 - (ii) Recognition and detection of cybersecurity threats and all types of cyber incidents;
 - (iii) Techniques used to circumvent cybersecurity measures;
 - (iv) Procedures for reporting a cyber incident to the CySO; and
 - (v) OT-specific cybersecurity training for all personnel whose duties include using OT.
 - (2) Key personnel with access to the IT or remotely accessible OT systems, including contractors, whether part-time, full-time, temporary, or permanent, must also have cybersecurity training in the following additional topics:
 - (i) Understanding their roles and responsibilities during a cyber incident and response procedure; and
 - (ii) Maintaining current knowledge of changing cybersecurity threats and countermeasures.
 - (3) When personnel must access IT or OT systems but are unable to receive cybersecurity training as specified in paragraphs (d)(1) and (2) of this section, they must be accompanied or monitored by a person who has completed the training specified in paragraphs (d)(1) and (2) of this section.
 - (4) All personnel must complete the training specified in paragraphs (d)(1)(ii) through (v) of this section by January 12, 2026, and annually thereafter. Key personnel must complete the training specified in paragraph (d)(2) of this section by January 12, 2026, and annually thereafter, or more frequently as needed. Training for new personnel not in place at the time of the effective date of this rule must be completed within 5 days of gaining system access, but no later than within 30 days of hiring, and annually thereafter. Training for personnel on new IT or OT systems not in place at the time of the effective date of this rule must be completed within 5 days of system access, and annually thereafter. All personnel must complete the training specified in paragraph (d)(1)(i) within 60 days of receiving approval of the Cybersecurity Plan. The training must be documented and maintained in the owner's or operator's records in accordance with 33 CFR 104.235 for U.S.-flagged vessels, 105.225 for facilities, and 106.230 for OCS facilities.
- (e) **Risk management.** Each owner or operator or designated CySO of a U.S.-flagged vessel, facility, or OCS facility must ensure the following measures for risk management are in place and documented in Sections 11 and 12 of the Cybersecurity Plan:

- (1) **Cybersecurity Assessment.** Each owner or operator or designated CySO of a U.S.-flagged vessel, facility, or OCS facility must ensure completion of a Cybersecurity Assessment that addresses each covered U.S.-flagged vessel, facility, and OCS facility. A Cybersecurity Assessment must be conducted no later than July 16, 2027, and annually thereafter. However, the Cybersecurity Assessment must be conducted sooner than annually if there is a change in ownership of a U.S.-flagged vessel, facility, or OCS facility. In conducting the Cybersecurity Assessment, the owner or operator must—
 - (i) Analyze all networks to identify vulnerabilities to critical IT and OT systems and the risk posed by each digital asset;
 - (ii) Validate the Cybersecurity Plan;
 - (iii) Document recommendations and resolutions in the Vessel Security Assessment (VSA), Facility Security Assessment (FSA), or OCS FSA, in accordance with 33 CFR 104.305, 105.305, and 106.305;
 - (iv) Document and ensure patching or implementing of documented compensating controls for all KEVs in critical IT or OT systems, without delay; and
 - (v) Incorporate recommendations and resolutions from paragraph (e)(1)(iii) of this section into the Cybersecurity Plan through an amendment, in accordance with § 101.630(e).
- (2) **Penetration testing.** In conjunction with Cybersecurity Plan renewal, the owner, operator, or designated CySO must ensure that a penetration test has been completed. Following the penetration test, a letter certifying that the test was conducted, as well as all identified vulnerabilities, must be included in the VSA, FSA, or OCS FSA, in accordance with 33 CFR 104.305, 105.305, and 106.305.
- (3) **Routine system maintenance.** Each owner or operator or a designated CySO of a U.S.-flagged vessel, facility, or OCS facility must ensure the following measures for routine system maintenance are in place and documented in Section 6 of the Cybersecurity Plan:
 - (i) Ensure patching or implementation of documented compensating controls for all KEVs in critical IT or OT systems, without delay;
 - (ii) Maintain a method to receive and act on publicly submitted vulnerabilities;
 - (iii) Maintain a method to share threat and vulnerability information with external stakeholders;
 - (iv) Ensure there are no exploitable channels directly exposed to internet-accessible systems;
 - (v) Ensure no OT is connected to the publicly accessible internet unless explicitly required for operation, and verify that, for any remotely accessible OT system, there is a documented justification; and
 - (vi) Conduct vulnerability scans as specified in the Cybersecurity Plan.
- (f) **Supply chain.** Each owner or operator or designated CySO of a U.S.-flagged vessel, facility, or OCS facility must ensure the following supply-chain measures are in place and documented in Section 4 of the Cybersecurity Plan:
 - (1) Consider cybersecurity capability as criteria for evaluation to procure IT and OT systems or services;

- (2) Establish a process through which all IT and OT vendors or service providers notify the owner or operator or designated CySO of any cybersecurity vulnerabilities or reportable cyber incidents, without delay; and
 - (3) Monitor and document all third-party remote connections to detect cyber incidents.
- (g) **Resilience.** Each owner or operator or designated CySO of a U.S.-flagged vessel, facility, or OCS facility must ensure the following measures for resilience are in place and documented in Sections 3 and 9 of the Cybersecurity Plan:
 - (1) For entities that have not reported to the Coast Guard pursuant to, or not subject to, 33 CFR 6.16-1, report reportable cyber incidents to the NRC without delay;
 - (2) In addition to other plans mentioned in this subpart, develop, implement, maintain, and exercise the Cyber Incident Response Plan;
 - (3) Periodically validate the effectiveness of the Cybersecurity Plan through annual exercises, annual reviews of incident response cases, or post-cyber incident review, as determined by the owner or operator; and
 - (4) Perform backup of critical IT and OT systems, with those backups being sufficiently protected and tested frequently.
- (h) **Network segmentation.** Each owner or operator or designated CySO of a U.S.-flagged vessel, facility, or OCS facility must ensure the following measures for network segmentation are in place and documented in Sections 7 and 8 of the Cybersecurity Plan:
 - (1) Implement segmentation between IT and OT networks; and
 - (2) Verify that all connections between IT and OT systems are logged and monitored for suspicious activity, breaches of security, TSIs, unauthorized access, and cyber incidents.
- (i) **Physical security.** Each owner, operator, or designated CySO of a U.S.-flagged vessel, facility, or OCS facility must ensure the following measures for physical security are in place and documented in Sections 7 and 8 of the Cybersecurity Plan:
 - (1) In addition to any other requirements in this part, limit physical access to OT and related IT equipment to only authorized personnel, and confirm that all HMIs and other hardware are secured, monitored, and logged for personnel access; and
 - (2) Ensure unauthorized media and hardware are not connected to IT and OT infrastructure, including blocking, disabling, or removing unused physical access ports, and establishing procedures for granting access on a by-exception basis.

§ 101.655 Cybersecurity compliance dates.

All Cybersecurity Plans mentioned in this subpart must be submitted to the Coast Guard for review and approval no later than July 16, 2027, according to 33 CFR 104.410 for U.S.-flagged vessels, 33 CFR 105.410 for facilities, or 33 CFR 106.410 for OCS facilities.

§ 101.660 Cybersecurity compliance documentation.

Each owner or operator must ensure that the cybersecurity portion of their Plan and penetration test results are available to the Coast Guard upon request. The Alternative Security Program provisions apply to cybersecurity compliance documentation and are addressed in 33 CFR 104.140 for vessels, 33 CFR 105.140 for facilities, and 33 CFR 106.135 for OCS facilities.

§ 101.665 Noncompliance, waivers, and equivalents.

An owner or operator, after completion of the required Cybersecurity Assessment, may seek a waiver or an equivalence determination for the requirements in subpart F using the standards and submission procedures applicable to a U.S.-flagged vessel, facility, or OCS facility as outlined in 33 CFR 101.130, 104.130, 104.135, 105.130, 105.135, 106.125, or 106.130. If an owner or operator must temporarily deviate from the requirements in this part, they must notify the cognizant COTP for facilities or OCS facilities, or the MSC for U.S.-flagged vessels, and may request temporary permission to continue to operate under the provisions as outlined in 33 CFR 104.125, 105.125, or 106.120.

§ 101.670 Severability.

Any provision of this subpart held to be invalid or unenforceable as applied to any person or circumstance shall be construed so as to continue to give the maximum effect to the provision permitted by law, including as applied to persons not similarly situated or to dissimilar circumstances, unless such holding is that the provision of this subpart is invalid and unenforceable in all circumstances, in which event the provision shall be severable from the remainder of this subpart and shall not affect the remainder thereof.